EBIOS RM — Analyse de risques

> ***Statut : cible.*** *Ce document décrit ce que l'équipe vise et a décidé, pas ce qui est déjà codé. L'état réel du code est suivi dans `constat/etat-implementation.md`.*

> *Ticket : WOR-31 · Responsable : Cédric · Version 0.3 du 21/10/2026*
>
> *Ateliers 1 et 2 : version 0.1, **validée par les coachs** (WOR-32). Ateliers 3 à 5 : ajoutés en version 0.2 (WOR-67), sur les composants réels relevés dans `constat/etat-implementation.md`.*

Hypothèses de travail

- L'entreprise est un **opérateur de paiement fictif**. Il traite les paiements de commerçants partenaires pour des utilisateurs finaux. Toutes les données sont fictives, sauf les empreintes faciales des membres de l'équipe enrôlés pour la double authentification du back-office.
- Le démonstrateur tourne sur **un seul PC Hôte**, avec Docker Compose sur le réseau `RESILIENCE-G6`. L'attaque vient d'un PC Attaquant distinct.
- Le coût d'un arrêt est chiffré dans `services-critiques.md` (WOR-68). Les objectifs RTO/RPO sont fixés dans `rto-rpo.md` (WOR-70).

Atelier 1 — Cadrage et socle de sécurité

1.1 Valeurs métier

ID	Valeur métier	Nature	Responsable métier (fictif)
VM1	Traitement des paiements : initier, autoriser, enregistrer une transaction	Processus	Direction des opérations
VM2	Consultation des transactions par les partenaires et les utilisateurs	Processus	Direction des opérations
VM3	Authentification et gestion des accès	Processus	RSSI
VM4	Données de comptes et de transactions	Information	DPO / Direction financière
VM5	Traçabilité : journaux et preuves d'audit	Information	RSSI / Conformité
VM6	Capacité de détection et de reprise automatique	Processus	Direction de la production

1.2 Biens supports

ID	Bien support	Valeurs métier portées
BS1	Front web de paiement	VM1, VM2
BS2	API métier de paiement (Node.js, `services/payment-api/backend/`)	VM1, VM2, VM4
BS3	Authentification intégrée à l'API (pas de service séparé), sessions en base ; dans le socle, elles sont en mémoire tant que l'API n'est pas branchée sur PostgreSQL	VM3
BS4	Base PostgreSQL (utilisateurs, sessions, intentions de paiement)	VM1, VM4
BS5	WAF / reverse proxy	VM1, VM2, VM3
BS6	Stack d'observabilité (Prometheus, Loki, Grafana) et SIEM	VM5, VM6
BS7	Service d'inférence ML (détection d'anomalies)	VM6

ID	Bien support	Valeurs métier portées
BS8	Moteur de remédiation, playbooks Ansible, accès au moteur Docker	VM6, puis indirectement toutes
BS9	Gestion des secrets (HashiCorp Vault)	VM3, VM4
BS10	Assistant RAG (Ollama, LangChain)	VM6 (aide aux opérateurs)
BS11	PC Hôte et réseau `RESILIENCE-G6`	Toutes
BS12	Dépôt Git et procédure de déploiement	VM6

> ***Point d'attention :*** *BS8 (le moteur de remédiation) a des droits élevés sur tous les conteneurs. C'est le bien support le plus sensible du dispositif (voir ER6).*
>
> ***Alignement sur le code (20/10) :*** *BS7 (inférence ML) et BS8 (remédiation) sont codés ; BS8 tourne sur l'hôte avec les droits Docker. BS5 (WAF) est déployé et l'API est derrière lui. Dans le socle, l'API garde ses données en mémoire (BS4 n'y est pas utilisée). Les vulnérabilités relevées dans le code (port de la base publié, secrets en clair, code de vérification renvoyé par l'API, appel à OpenAI) sont listées dans `constat/etat-implementation.md` §3 et sont traitées dans les ateliers 4 et 5.*

1.3 Événements redoutés

Échelle de gravité : **G1** mineure · **G2** significative · **G3** grave · **G4** critique.

Pour une indisponibilité, l'échelle est chiffrée dans `services-critiques.md` (WOR-68) : G1 ≤ 5 min (~1,5 k€), G2 ≤ 30 min (~10 k€), G3 ≤ 2 h (~700 k€, SLA dépassé), G4 > 2 h (> 1,5 M€, incident majeur DORA).

ID	Événement redouté	VM	Impacts	Gravité
ER1	Paiements indisponibles au-delà du RTO	VM1	Transactions des partenaires bloquées, perte de chiffre d'affaires, perte de confiance, incident majeur à déclarer (DORA)	**G4**
ER2	Transactions altérées ou incohérentes (montant modifié, double débit, transaction fantôme)	VM1, VM4	Préjudice financier direct, litiges, données comptables fausses	**G4**
ER3	Fuite des données de comptes ou de transactions	VM4	Atteinte à la vie privée (RGPD), sanctions, atteinte à l'image	**G3**
ER4	Accès non autorisé à un compte (usurpation d'identité)	VM3	Fraude, opérations frauduleuses initiées	**G3**
ER5	Journaux perdus ou altérés	VM5	Investigation impossible, preuves perdues, non-conformité	**G3**
ER6	Moteur de remédiation détourné ou en erreur (arrêt de services, restauration de mauvaises données)	VM6 → VM1	Interruption provoquée par le dispositif de défense lui-même, possibilité de rebond sur tout le SI	**G4**
ER7	Consultation des transactions indisponible	VM2	Gêne pour les partenaires, appels au support	**G2**

1.4 Socle de sécurité

Référentiel	Applicabilité	Écarts connus à ce stade
DORA (règlement UE 2022/2554)	Applicable : entité financière	Pas de tests de résilience menés par un tiers, pas de gestion des prestataires TIC (voir WOR-69)
NIS2 (directive UE 2022/2555)	Non applicable : les établissements de paiement ne sont pas à l'annexe I. Pour les entités financières, DORA prime de toute façon	Voir `nis2-dora.md` (WOR-69)
RGPD	Applicable par principe (données personnelles fictives)	Aucune donnée réelle, donc écart sans conséquence pour le prototype
Guide d'hygiène informatique de l'ANSSI	Bonnes pratiques de référence	Hôte unique (point de défaillance unique), pas de sauvegarde hors site
PCI DSS	Référence du secteur pour les données de carte	**Hors périmètre** : aucune donnée de carte manipulée

---

Atelier 2 — Sources de risque et objectifs visés

Cotation de la pertinence : **1** faible · **2** moyenne · **3** forte. Elle combine la motivation, les ressources et l'activité constatée de la source.

ID	Source de risque (SR)	Objectif visé (OV)	Motivation	Ressources	Pertinence	Retenu ?
SR1	Cybercriminel organisé	Gain financier : fraude aux paiements, rançongiciel	Forte	Importantes	**3**	✅
SR2	Hacktiviste	Visibilité, nuire à l'image : déni de service	Moyenne	Moyennes (botnets loués)	**3**	✅
SR3	Initié malveillant (employé, prestataire)	Vengeance ou gain : sabotage, fraude interne	Moyenne	Accès légitimes	**2**	✅
SR4	Attaquant opportuniste	Défi, revente d'accès : exploitation d'une vulnérabilité web, bourrage d'identifiants	Faible	Outils publics	**2**	✅
SR5	Concurrent ou officine d'espionnage	Vol de données commerciales	Faible	Moyennes	1	❌ données fictives, sans valeur concurrentielle
SR6	Acteur étatique (APT)	Déstabiliser le secteur financier	Faible pour une petite entité	Très importantes	1	❌ hors de portée d'un prototype de 4 jours, cité comme risque résiduel

> *Les événements non intentionnels (erreur d'exploitation, panne, faux positif du modèle ML) ne sont pas des sources de risque au sens d'EBIOS. Ils seront traités dans le PCA/PRA (WOR-71).*

Matrice de risques initiale

Vraisemblance provisoire : **V1** peu vraisemblable · **V2** vraisemblable · **V3** très vraisemblable · **V4** quasi certain. Elle est affinée dans l'atelier 4 ; le risque résiduel est dans l'atelier 5.

ID	Risque (SR → mode d'action → ER)	Gravité	Vraisemblance	Niveau
R1	SR2 → déni de service applicatif sur l'API ou le front → ER1	G4	V3	🔴 Élevé
R2	SR1 → injection applicative sur l'API → ER2	G4	V2	🔴 Élevé
R3	SR3 → détournement des droits du moteur de remédiation → ER6	G4	V2	🔴 Élevé
R4	SR4 → bourrage d'identifiants ou force brute sur l'authentification → ER4	G3	V3	🟠 Significatif
R5	SR1 → compromission puis exfiltration de la base → ER3	G3	V2	🟠 Significatif
R6	SR3 → effacement ou altération des journaux → ER5	G3	V2	🟠 Significatif
R7	SR1 → rançongiciel sur le PC Hôte → ER1, ER3	G4	V1	🟠 Significatif
R8	SR2 → saturation de la consultation → ER7	G2	V3	🟡 Modéré

Cartographie

Gravité \ Vraisemblance	V1	V2	V3	V4
G4	R7	R2, R3	**R1**	
G3		R5, R6	R4	
G2			R8	
G1				

Lecture

- **R1 (déni de service)** est le risque le plus élevé. C'est aussi le meilleur candidat pour le scénario d'attaque de la démo (WOR-29) : effet observable, détectable par le ML et réparable automatiquement.
- **R2 et R5** (injection, exfiltration) appellent une réponse différente d'une simple restauration de la disponibilité. Le sujet demande explicitement de ne pas confondre les deux (voir WOR-39).
- **R3** porte sur notre propre dispositif de défense. Il justifie WOR-64 (sécuriser le moteur de remédiation), que le jury évalue sur l'Axe 2.

Atelier 3 — Scénarios stratégiques

3.1 Écosystème

Les parties prenantes par lesquelles une attaque peut passer. Chaque critère est coté de 1 (faible) à 4 (fort). **Menace = (dépendance × pénétration) / (maturité cyber × confiance)** ; au-delà de 2, la partie prenante est jugée critique. Les cotes sont des estimations pour l'entreprise fictive.

ID	Partie prenante	Accès au système	Dép.	Pén.	Mat.	Conf.	Menace
PP1	Partenaires commerçants (200) et utilisateurs finaux	API derrière le WAF, comptes clients	4	2	1	1	**8** critique

ID	Partie prenante	Accès au système	Dép.	Pén.	Mat.	Conf.	Menace
PP2	Autres postes du réseau `RESILIENCE-G6`	Ports exposés de l'hôte : WAF (8080), base de l'application (55432)	1	3	1	1	**3** critique
PP3	Exploitants (équipe projet)	Comptes de l'hôte, droits Docker, Vault, dépôt Git	4	4	2	3	**2,7** critique
PP5	Service d'inférence ML	Clé HMAC qui autorise les ordres au moteur de remédiation	4	3	2	3	**2** critique
PP4	Prestataires TIC : OpenAI, registres d'images, dépendances npm et Python	Appels sortants, code tiers exécuté dans les conteneurs	2	2	3	2	0,7

Mesures sur l'écosystème : filtrage et blocage des clients au WAF (PP1, PP2), signature des alertes (PP5), registre des prestataires TIC (PP4, REC-11). Le cloisonnement des exploitants (PP3) n'est pas traité dans le prototype.

3.2 Scénarios stratégiques

ID	Source → objectif	Chemin dans l'écosystème	Événement redouté	Gravité
SS1	SR2 hacktiviste → nuire à l'image	Depuis le réseau (PP2) ou en se faisant passer pour des clients (PP1), saturer l'API	ER1 paiements indisponibles	G4
SS2	SR1 cybercriminel → gain financier	Compte client (PP1) → injection dans l'API → transactions modifiées	ER2 transactions altérées	G4
SS3	SR1 cybercriminel → revente de données	Réseau (PP2) → base de l'application exposée	ER3 fuite de données	G3
SS4	SR3 initié → sabotage	Droits d'exploitant (PP3) ou service d'inférence compromis (PP5) → ordres au moteur de remédiation	ER6 défense détournée, puis ER1 et ER2	G4
SS5	SR4 opportuniste → fraude	Comptes clients (PP1) → bourrage d'identifiants → paiements	ER4 usurpation	G3
SS6	SR3 initié → effacer ses traces	Droits d'exploitant (PP3) → remise à l'état sain ou purge de Loki	ER5 journaux perdus	G3

Atelier 4 — Scénarios opérationnels

Chaque scénario suit les composants réels du démonstrateur (`constat/etat-implementation.md`). La vraisemblance tient compte des mesures **déjà codées**.

Scénario	Étapes de l'attaque	Ce qui la freine aujourd'hui	Vraisemblance
SO1 (SS1, R1) Déni de service	1. Rafale de requêtes depuis le PC Attaquant vers le WAF (port 8080) · 2. L'API, limitée à 0,75 CPU, sature ou renvoie des erreurs · 3. Les paiements légitimes échouent	Limite de 60 requêtes par minute et par client ; détection ML, puis blocage en 403 des IP qui pèsent au moins 20 % parmi les 5 plus actives ; redémarrage si besoin	**V3** : outil public. Une attaque répartie sur beaucoup d'IP perd 5 sources par alerte, mais les autres continuent

Scénario	Étapes de l'attaque	Ce qui la freine aujourd'hui	Vraisemblance
SO2 (SS2, R2) Injection	1. Requêtes avec motifs d'injection vers une route `/v1/…` · 2. Une variante passe le WAF · 3. Elle atteint le stockage de l'API	OWASP CRS bloquant : 9 vecteurs sur 10 en 403 ; détection de la famille `injection` ; blocage de la source	**V1** : le WAF arrête presque tout, et l'API du socle n'a pas de base. Réserve : l'attaque B vise encore `/api/pay`, qui n'existe pas ; le chemin jusqu'à l'API n'a pas été essayé
SO2b (SS2, R2) Restauration provoquée	1. Une seule requête d'injection, même bloquée par le WAF · 2. La détection lève une alerte `sqli` légitime · 3. Le moteur restaure : toutes les transactions sont effacées	Aucune : le moteur restaure sans vérifier que l'injection a réussi	**V3** : une requête suffit (`ml/training/README.md`). Le 21/10, deux fausses alertes ont produit le même effet sans attaque
SO3a (SS4, R3) Restauration abusive	1. Accès à l'hôte, ou compromission du service d'inférence, qui détient la clé HMAC · 2. Alerte `sqli` forgée et signée · 3. Le moteur restaure sans validation humaine : toutes les transactions sont effacées	Signature HMAC, refus des alertes anciennes ou rejouées, liste fermée de playbooks, écoute sur la loopback et la passerelle Docker (jamais sur le réseau)	**V2** : la clé et les droits Docker sont sur l'hôte, sans cloisonnement entre exploitants
SO3b (SS4, R3) Blocage de clients légitimes	Même accès · alerte `dos` forgée avec les IP des partenaires	Les IP de l'hôte ne sont jamais bloquées ; rien ne protège celles des partenaires	**V2**
SO4 (SS3, R5) Exfiltration	1. Depuis le réseau, connexion au port 55432 · 2. Mot de passe lu dans le dépôt · 3. Copie de la base	Aucune, si le déploiement autonome de Pay&Go (`services/payment-api/infra/`) tourne	**V3** : trivial. Sans objet pour le socle, qui n'expose que le WAF au réseau
SO5 (SS5, R4) Usurpation	1. Essais d'identifiants sur `/v1/auth/login` · 2. Session obtenue · 3. Paiement validé avec le code renvoyé par l'API (`demoCode`)	12 essais par 15 min et par client ; **identifiant verrouillé après 2 échecs** (5 min, puis 10, 15…) ; visage exigé avant le mot de passe pour les comptes du back-office enrôlés	**V1** : deviner un mot de passe devient impraticable. Restent la réutilisation d'un mot de passe connu (un essai par compte) et un code de paiement qui ne protège rien
SO5b (SS5, R4) Usurpation d'un administrateur sur place	1. Accès physique au poste du back-office (la consigne additionnelle 1 cite des attaques physiques) · 2. Photo de l'administrateur devant la caméra · 3. Mot de passe obtenu par ailleurs	Visage **et** mot de passe exigés ; 2 échecs verrouillent l'identifiant ; LED rouge visible sur place	**V2** : le modèle ne vérifie pas qu'il s'agit d'un visage vivant, une photo peut suffire. Il faut quand même le mot de passe
SO6 (SS6, R6) Effacement des journaux	1. Exploitant malveillant sur l'hôte · 2. Remise à l'état sain ou purge des volumes · 3. Les journaux de Loki disparaissent	Export des journaux avec empreintes (`scripts/export-logs.sh`), mais à lancer à la main	**V2**

R7 (rançongiciel, V1) et R8 (même chemin que SO1) ne sont pas détaillés.

Atelier 5 — Traitement du risque

Règle des niveaux, identique à la matrice initiale : 🔴 si G4 et V2 ou plus ; 🟠 si G4·V1, ou G3 et V2 ou plus ; 🟡 sinon.

5.1 Mesures et risque résiduel

Démo = mesure à faire avant les essais ; sinon, mesure pour un contexte industriel (`recommandations.md`).

Risque	Mesures en place	Résiduel actuel	Mesures complémentaires	Résiduel visé
R1 déni de service	Limite par client, blocage au WAF, redémarrage vérifié par une transaction	G2·V2 🟡, sous réserve du RTO mesuré (WOR-79) ; un partenaire bloqué à tort le reste jusqu'à une action manuelle	**Démo :** levée automatique des blocages. Industriel : protection en amont (REC-10)	G2·V2 🟡
R2 injection	WAF CRS bloquant, détection, blocage, retour à l'état sain	G4·V3 🔴 : une seule tentative d'injection, même bloquée, déclenche la restauration qui efface toutes les transactions (SO2b)	**Démo :** ne pas restaurer quand le WAF a tout bloqué, API sur PostgreSQL, sauvegarde avant essai, attaque B recâblée. Industriel : correction du code, restauration à un instant précis (REC-6)	G3·V1 🟡 avec REC-6
R3 remédiation détournée	Signature HMAC, liste fermée, garde-fous, écoute hors réseau	G4·V2 🔴	**Démo :** moteur en conteneur, sans droits Docker complets. Industriel : REC-2, REC-3, REC-4	G4·V1 🟠
R4 usurpation	Limite de 12 essais par 15 min, verrouillage progressif de l'identifiant, visage exigé pour le back-office	G3·V2 🟠 : un visage en photo peut passer (SO5b) ; deviner un mot de passe est devenu impraticable (SO5)	**Démo :** ne plus renvoyer le code de vérification. Industriel : double authentification pour les clients, détection du vivant pour la reconnaissance faciale (SO5b)	G3·V1 🟡
R5 exfiltration	Socle : seul le WAF est exposé au réseau	G3·V3 🟠 si le déploiement autonome de Pay&Go tourne	**Démo :** fermer le port 55432, secrets de l'application dans Vault	G3·V1 🟡
R6 journaux	Export avec empreintes, Loki 7 jours	G3·V2 🟠	**Démo :** export appelé avant toute restauration ou remise à l'état sain. Industriel : journaux hors de l'hôte, immuables	G3·V1 🟡
R7 rançongiciel	Aucune	G4·V1 🟠	Industriel : sauvegardes hors site, deuxième site (REC-5, REC-9)	G4·V1 🟠
R8 consultation	Même chaîne que R1	G2·V2 🟡	—	G2·V2 🟡

5.2 Cartographie du risque résiduel

Gravité \ Vraisemblance	V1	V2	V3	V4
G4	R7	**R3**	**R2**	
G3		R4, R6	R5	
G2		R1, R8		

Actuel. Une fois les mesures « démo » faites : R2 passe en G4·V1, R3 en G4·V1, R5 et R6 en G3·V1 ; R4 attend la détection du vivant pour passer en G3·V1.

5.3 Acceptation du risque résiduel

Risque	Décision	Par qui	Jusqu'à quand
R3	Accepté pour la démo : la restauration automatique sans validation humaine est un choix de démonstration	Direction générale (fictive), à la présentation finale	Mise en production, qui exige REC-2, REC-3 et REC-4
R2	Accepté, une fois la restauration réservée aux injections qui passent le WAF : perte des transactions à chaque restauration	Idem	Mise en place de REC-6
R7	Accepté : hôte unique, sans sauvegarde hors site	Idem	Mise en place de REC-5 et REC-9
R1, R8	Accepté en G2, si le RTO mesuré le confirme	Idem	Revue après les essais (WOR-79)

5.4 Plan d'amélioration

Mesure	Risques	Responsable	Échéance	Comment on le vérifie
API du socle sur PostgreSQL, `pg_dump` avant chaque essai	R2, RPO	Reza, Michael	Avant les essais	Comptage des transactions avant et après restauration (WOR-75)
Attaque B sur une route `/v1/…`	R2	Axel	Avant les essais	Répétitions (WOR-78)
Pas de restauration quand le WAF a bloqué toutes les requêtes d'injection	R2	Michael, Léa	Avant les essais	Une requête d'injection bloquée : blocage de la source, aucune restauration
Consentement écrit des personnes enrôlées, effacement des visages après la démo	ER3, RGPD	Cédric, Axel	Avant la démo / après la démo	Formulaires signés ; volume `face-data` purgé
Modèle évalué sur des fenêtres d'attaque	R1, R2, R3	Léa	Avant les essais	Rapport d'entraînement : taux et délai de détection (WOR-52)
Code de vérification non renvoyé	R4	Michael	Avant les essais	Appel à l'API
Port 55432 fermé, secrets de l'application dans Vault	R5	Axel	Avant les essais	Scan de ports depuis le PC Attaquant
Export des journaux avant restauration et remise à l'état sain	R6	Michael, Reza	Avant les essais	Dossier de preuves après chaque essai
Levée automatique des blocages	R1	Michael	Fin du workshop	Chaos engineering (WOR-76)
Moteur en conteneur, droits limités	R3	Michael, Axel	Fin du workshop	Revue des droits (WOR-64)
REC-2 à REC-6, REC-9 à REC-11	Tous	Direction (fictive)	6 à 12 mois	Voir `recommandations.md`